

Automated Cross-Framework Mapping of AI Security Controls via Multi-Signal Stacking and Conformal Prediction

Rock Lambros
ORCID: 0009-0004-3568-6151

April 12, 2026

Abstract

Organizations adopting AI systems must comply with a growing number of overlapping security frameworks, yet no shared vocabulary exists across them. Manual crosswalks are expensive, error-prone, and quickly become stale as frameworks evolve. We present an automated approach for mapping controls across nine major AI security and governance frameworks, constructing a heterogeneous knowledge graph of 983 control nodes integrated from four complementary data sources: within-framework hierarchies, community-contributed upstream mappings, cross-reference tables, and bootstrap-pruned anchor pairs. Our method combines LLM-derived similarity features with structural graph features and calibrated LLM-as-judge tier scores, feeding a LightGBM stacker that classifies control pairs into four tiers: *equivalent*, *related*, *partial*, and *unrelated*. Mondrian conformal prediction provides per-class coverage guarantees, and a KL-divergence router flags uncertain predictions for human review. On 400 expert-labeled frozen test pairs the system achieves tier accuracy of 0.53 (95% CI [0.485, 0.580]), macro F1 of 0.49, and adjacent accuracy of 0.84. Conformal prediction attains 93.8% empirical coverage at $\alpha = 0.10$ with a mean prediction set size of 3.2. Ablation analysis confirms that each feature family contributes complementary signal, with Opus tier scores providing the strongest individual channel. All code, data splits, and model weights are released under Apache-2.0 with a one-command reproducibility target.

1 Introduction

The rapid proliferation of AI security frameworks has created a compliance landscape in which organizations must simultaneously satisfy multiple overlapping standards. Frameworks such as the NIST AI Risk Management Framework [National Institute of Standards and Technology, 2023], MITRE ATLAS [MITRE Corporation, 2024], the OWASP Top 10 for LLM Applications [OWASP Foundation, 2025], and the CSA AI Controls Matrix [Cloud Security Alliance, 2024] each use their own taxonomy, control identifiers, and terminology, making it difficult for practitioners to determine which controls in one framework correspond to controls in another.

Manual crosswalk construction is the current industry practice. Subject matter experts review pairs of controls across frameworks and assign equivalence judgments. This process is slow (a single multi-framework crosswalk can take hundreds of hours), subjective (inter-annotator agreement is often low for partial-overlap cases), and brittle (each framework revision invalidates portions of the mapping).

We propose an automated crosswalk system that scales to arbitrary framework pairs. Our pipeline ingests framework control texts, builds a multi-framework knowledge graph from four complementary data sources, and trains a supervised classifier to assign one of four relationship tiers to each candidate control pair. The system incorporates three signal families: (1) LLM-derived semantic similarity features, (2) structural graph features from the control knowledge graph, and (3) calibrated LLM-as-judge tier scores from a Claude Opus evaluator.

A Mondrian conformal prediction wrapper provides finite-sample coverage guarantees per class, and a KL-divergence router identifies predictions where the model is uncertain, routing them to human reviewers. The result is a human-in-the-loop system that automates the bulk of crosswalk construction while preserving expert oversight where it matters most.

We evaluate on 400 expert-labeled frozen test pairs spanning 15 framework pairs across nine AI security and governance frameworks, achieving tier accuracy of 0.53 with a bootstrap 95% confidence interval of [0.485, 0.580] and macro F1 of 0.49. Adjacent accuracy (predictions within one tier of ground truth) reaches 0.84, and Mondrian conformal prediction achieves 93.8% empirical coverage at $\alpha = 0.10$.

2 Related Work

Security framework crosswalks. Manual crosswalks between cybersecurity frameworks have a long history. NIST maintains mappings between SP 800-53 and ISO 27001, and the Cloud Security Alliance publishes the Cloud Controls Matrix with pre-built mappings to multiple standards. In the AI-specific domain, the *GenAI Security Project* has produced a community-driven crosswalk covering several major AI security frameworks [GenAI Security Project Contributors, 2024]. Our work uses the GenAI Security Project crosswalk as an upstream data source for prior-edge construction and acknowledges its contribution under the CC BY-SA 4.0 license. To our knowledge, no prior work has attempted to *automate* the crosswalk process for AI security frameworks using machine learning at this scale.

Graph neural networks for knowledge graphs. Graph attention networks [Veličković et al., 2018] and their successors such as GATv2 [Brody et al., 2022] have been widely used for link prediction and node classification in knowledge graphs. While our current feature pipeline extracts structural graph features directly rather than training a GATv2 end-to-end, the graph construction and feature extraction approach is informed by this literature, and GATv2-based node embeddings remain a planned extension.

Conformal prediction for classification. Conformal prediction [Vovk et al., 2005] provides distribution-free coverage guarantees for classification. Mondrian conformal prediction [Romano et al., 2020] extends this to per-class calibration, which is essential in our setting due to severe class imbalance across the four tiers. We adopt Mondrian conformal prediction to provide per-tier coverage guarantees for the crosswalk classifier.

LLM-as-judge evaluation. Recent work has demonstrated that large language models can serve as effective evaluators for subjective tasks, including semantic similarity judgment and text classification. We incorporate LLM-as-judge tier scores as features in our stacking classifier, treating the LLM judgment as a calibrated prior that the gradient boosting model refines using structural and embedding-based evidence.

Gradient-boosted ensembles. LightGBM [Ke et al., 2017] is a widely adopted gradient boosting framework that handles heterogeneous feature types (dense embeddings, sparse lexical scores, graph metrics, and discrete LLM judgments) in a single model. We use LightGBM as our stacking classifier over features from all three signal families.

3 Method

Our pipeline comprises four stages: feature extraction, stacking classification, conformal calibration, and uncertainty routing.

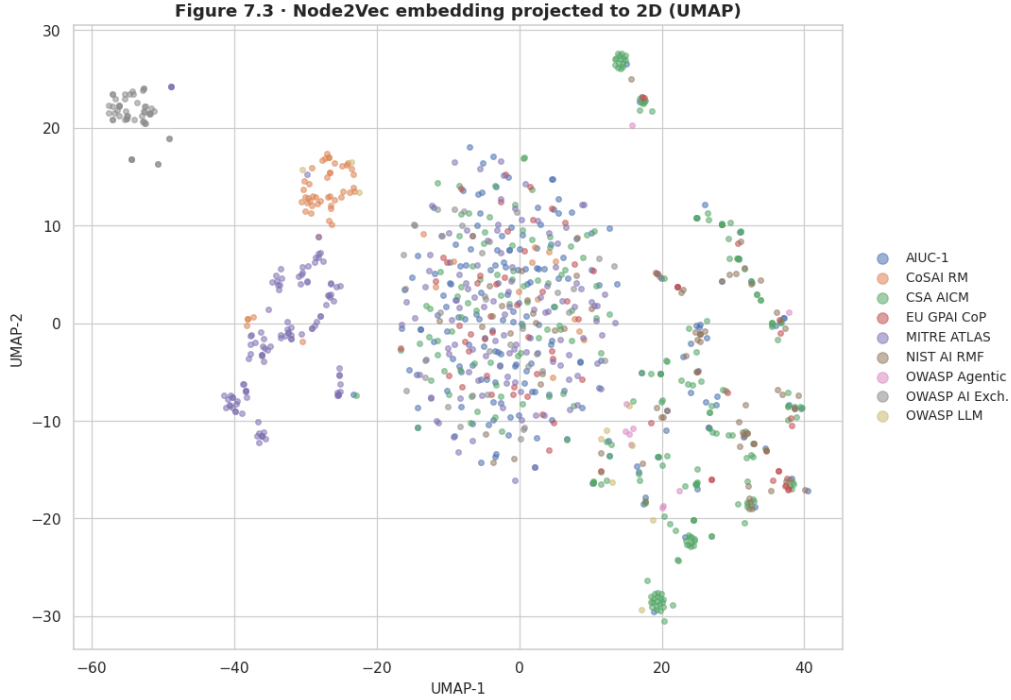


Figure 1: Node2Vec embeddings projected to 2D via UMAP, colored by framework. Clusters correspond to individual frameworks, with cross-framework bridge edges creating inter-cluster connections that the structural features capture.

3.1 Feature Extraction

For each candidate control pair (u, v) , we extract a 22-dimensional feature vector organized into three families:

LLM similarity features (7 dimensions). We compute dense semantic similarity using BGE-large (1024-d) embeddings, yielding cosine similarity between control texts. Additional lexical features include BM25 scores computed over control titles and descriptions after tokenization and stopword removal, Jaccard coefficient over token sets, and character n-gram overlap measures. Structural similarity scores derived from shared graph neighborhood statistics complete this family.

Structural graph features (13 dimensions). We construct a heterogeneous control graph with 983 nodes and edges integrated from the four sources described in Section 4. From this graph we extract pairwise features including shortest-path distance, common-neighbor count, Jaccard index of neighbor sets, Adamic-Adar index, bridge centrality scores, degree-product features, and framework-pair indicators. These features capture topological proximity: controls connected through multiple paths receive high structural similarity scores regardless of surface-level text overlap. Figure 1 visualizes the graph structure via a UMAP projection of Node2Vec embeddings, revealing framework-level clustering with cross-framework bridges.

Opus tier scores (2 dimensions). A Claude Opus evaluator independently assigns each candidate pair a tier judgment (0–3) and a confidence score. These two features provide a calibrated LLM-as-judge signal that complements the embedding-based similarity features with holistic semantic reasoning.

3.2 LightGBM Stacker

The 22-dimensional feature vector is fed to a LightGBM [Ke et al., 2017] multiclass classifier that predicts one of four tiers: *unrelated* (0), *partial* (1), *related* (2), and *equivalent* (3). The model uses `n_estimators` = 500, learning rate 0.05, and `min_samples_leaf` = 5. Inverse-frequency class weights address the severe class imbalance in the training data.

3.3 Mondrian Conformal Prediction

We wrap the LightGBM classifier with a Mondrian conformal predictor calibrated on a held-out set of $n_{\text{cal}} = 150$ pairs. For each test instance, the conformal predictor outputs a prediction set guaranteed to contain the true label with probability $\geq 1 - \alpha$ within each class stratum, providing distribution-free coverage guarantees [Vovk et al., 2005, Romano et al., 2020].

3.4 KL-Divergence Router

A KL-divergence router compares the predicted class distribution against a uniform reference distribution. Instances with high KL divergence (confident predictions) are accepted; those with low divergence (uncertain predictions) are routed to human review. This creates a natural human-in-the-loop workflow where experts focus on the most ambiguous cases.

4 Dataset

4.1 Frameworks

We ingest nine AI security and governance frameworks spanning risk management, technical controls, threat modeling, and compliance guidance:

1. **NIST AI RMF** [National Institute of Standards and Technology, 2023] — 76 controls covering AI risk governance and lifecycle management.
2. **MITRE ATLAS** [MITRE Corporation, 2024] — 218 entries cataloging adversarial tactics, techniques, and procedures targeting AI systems.
3. **OWASP Top 10 for LLM Applications** [OWASP Foundation, 2025] — 10 high-level vulnerability categories for large language model deployments.
4. **OWASP Agentic AI Security Risks** — 10 risk categories specific to autonomous AI agent architectures.
5. **OWASP AI Exchange** — 88 entries providing a cross-cutting taxonomy of AI security threats and mitigations.
6. **CSA AI Controls Matrix** [Cloud Security Alliance, 2024] — 261 controls organized by domain (IAM, data security, model governance, etc.) for cloud-hosted AI workloads.
7. **CoSAI Risk Model** — 61 risk entries from the Coalition for Secure AI covering supply chain, inference, and deployment risks.
8. **AI Use Case Framework (AIUC)** — 189 entries cataloging governance requirements across AI application categories.
9. **EU GPAI Code of Practice** — 70 entries derived from the European Union’s General-Purpose AI Code of Practice for providers of foundation models.

Together these yield 983 control nodes. Framework sizes range from 10 entries (OWASP LLM, OWASP Agentic) to 261 (CSA AICM), reflecting the heterogeneous granularity of real-world AI governance standards.

Figure 3.3 · Categorical composition of the corpus

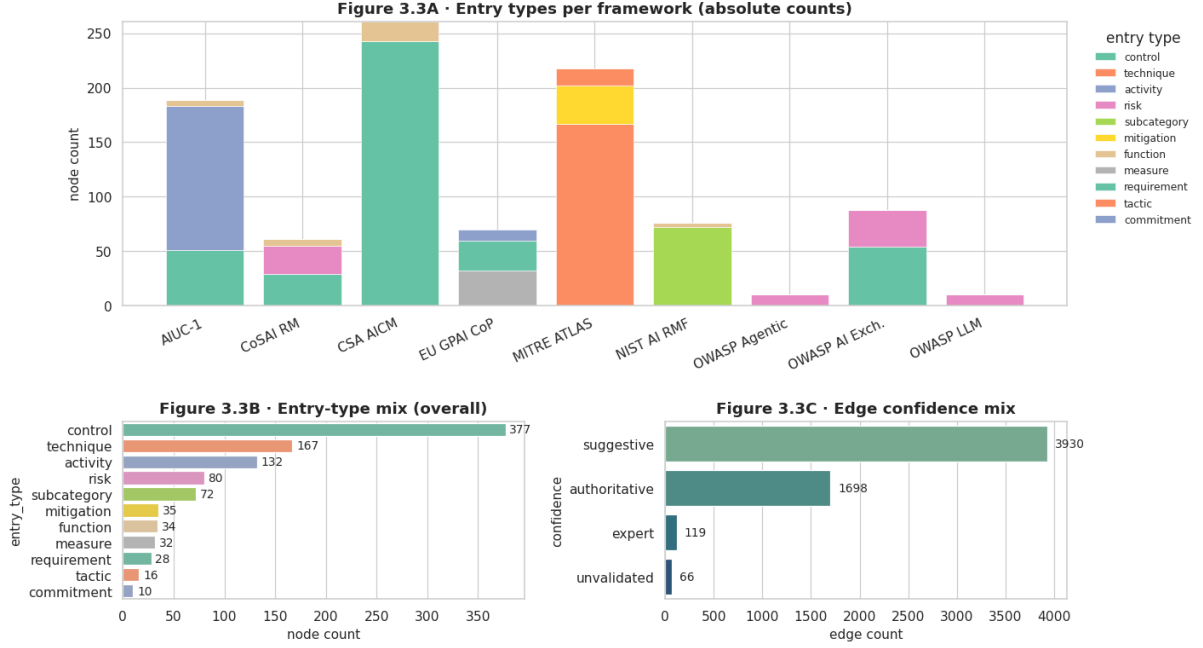


Figure 2: Categorical composition of the corpus. (A) Entry types per framework showing absolute counts. (B) Overall entry-type distribution. (C) Edge confidence distribution across the knowledge graph.

4.2 Graph Structure and Data Sources

The control knowledge graph integrates edges from four complementary sources, each capturing a different type of inter-control relationship:

1. **Within-framework hierarchies and cross-framework graph edges** (5,813 edges total: 1,090 intra-framework parent-child relationships plus 4,723 cross-framework edges derived from high-confidence BM25 bridge matching).
2. **Upstream community mappings** from the GenAI Security Project crosswalk [GenAI Security Project Contributors, 2024] (3,210 total rows; 209 in-scope after filtering to the nine included frameworks), used under CC BY-SA 4.0.
3. **Upstream cross-reference tables** (363 total rows; 58 in-scope), capturing additional control relationships published alongside framework documentation.
4. **Bootstrap-pruned anchor pairs** from 12 pair-config files (816 total anchor pairs), generated via co-citation analysis followed by bootstrap cross-validation pruning to remove unstable candidates.

After deduplication, these four sources produce cross-framework edges spanning 15 unique framework pairs out of the $\binom{9}{2} = 36$ possible pairs, yielding a graph connectivity of 41.7%. Figure 3 visualizes the direction-agnostic edge distribution across all framework pairs.

4.3 Labeling Protocol

We employ a two-stage labeling protocol:

The crosswalk landscape: hub-and-spoke by design

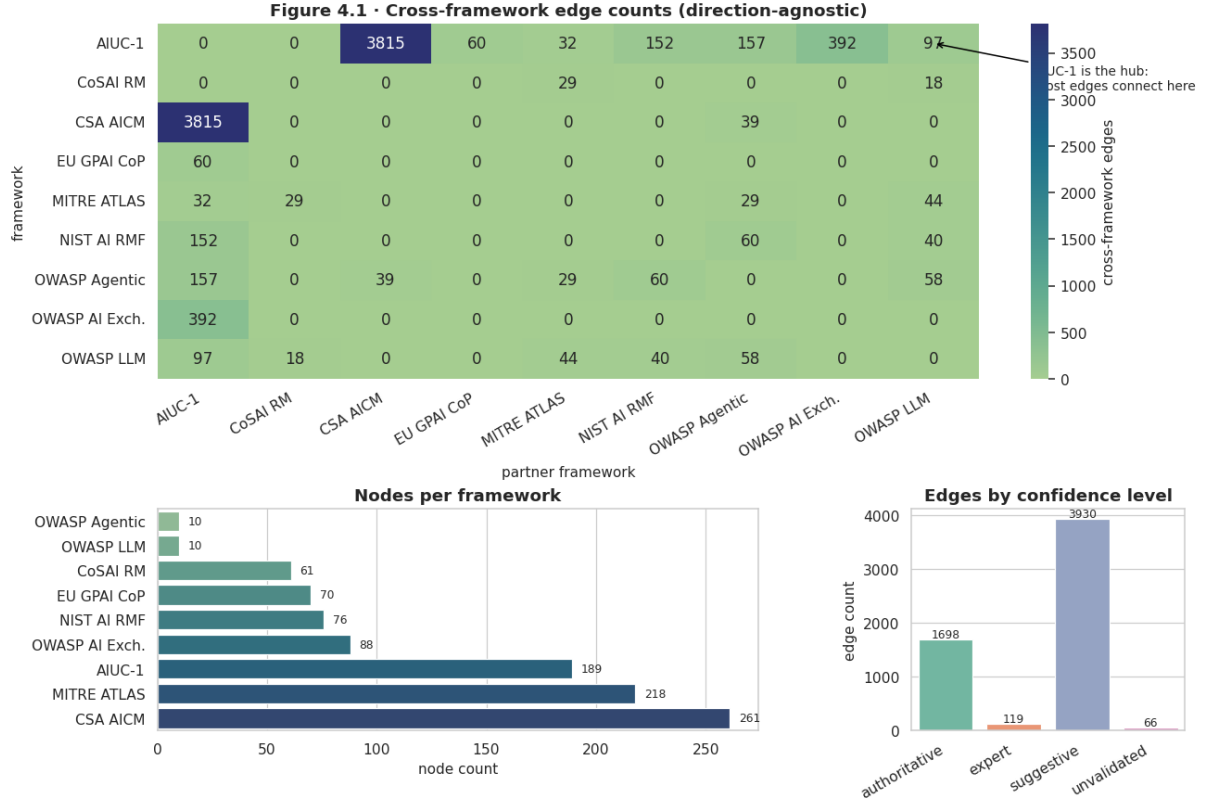


Figure 3: Cross-framework edge counts (direction-agnostic). Left: heatmap of pairwise edge counts after symmetrizing. Right: marginal totals per framework. CSA AICM and AIUC-1 dominate connectivity due to their large control inventories and extensive upstream mappings.

1. **LLM-SME silver labels.** A structured prompt elicits tier judgments from a large language model acting as a simulated subject matter expert. Each pair receives a tier label (0–3) and a free-text rationale. 1,515 training pairs and 379 validation pairs are labeled this way.
2. **Expert gold labels.** A human expert independently labels 400 pairs using the same four-tier scheme. These form the frozen test set (`v1_frozen`) used for all reported metrics. The frozen split is SHA-verified and never used during training or hyperparameter selection.

4.4 Tier Scheme

The four tiers capture decreasing degrees of semantic overlap:

Equivalent (3): Controls address the same requirement with comparable specificity.

Related (2): Controls address overlapping concerns but differ in scope or granularity.

Partial (1): One control partially addresses the other’s requirement.

Unrelated (0): No meaningful semantic overlap.

The frozen test set is class-imbalanced: Related pairs dominate ($186/400 = 46.5\%$), with Unrelated and Partial each at $78/400$ (19.5%) and Equivalent at $58/400$ (14.5%).

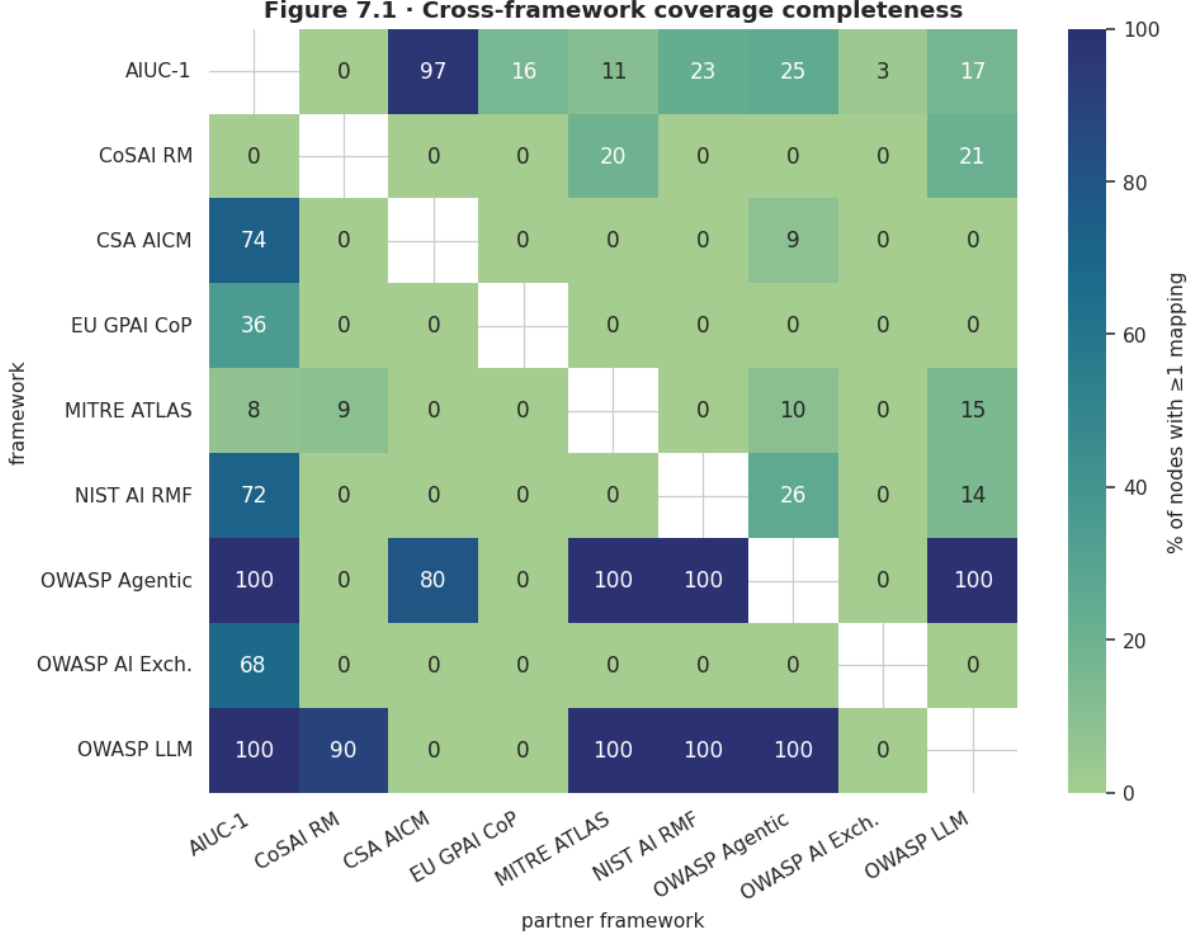


Figure 4: Cross-framework coverage completeness. Each cell shows the fraction of possible control pairs between two frameworks that have at least one edge in the unified knowledge graph. Coverage ranges from dense (e.g., AIUC–CSA AICM) to zero for unconnected pairs.

5 Experimental Setup

5.1 Feature Set

The full feature vector comprises 22 dimensions organized into three families:

- **LLM features (7d)**: BGE-large cosine similarity, BM25 score, Jaccard coefficient, character n-gram overlap, and neighborhood-derived similarity measures.
- **Structural features (13d)**: Shortest-path distance, common-neighbor count, neighbor-set Jaccard index, Adamic-Adar index, bridge centrality, degree-product features, and framework-pair indicators derived from the four-source knowledge graph.
- **Opus features (2d)**: Claude Opus tier prediction (0–3) and associated confidence score.

Figure 5 shows the distribution of six representative features stratified by expert tier, illustrating the discriminative signal available in each family. Figure 6 presents the Pearson correlation matrix across all 22 features, revealing that the three families capture largely orthogonal signals.

5.2 Training Configuration

- **Classifier**: LightGBM multiclass (softmax objective).

Figure 5.1 · v6 feature distributions by expert tier

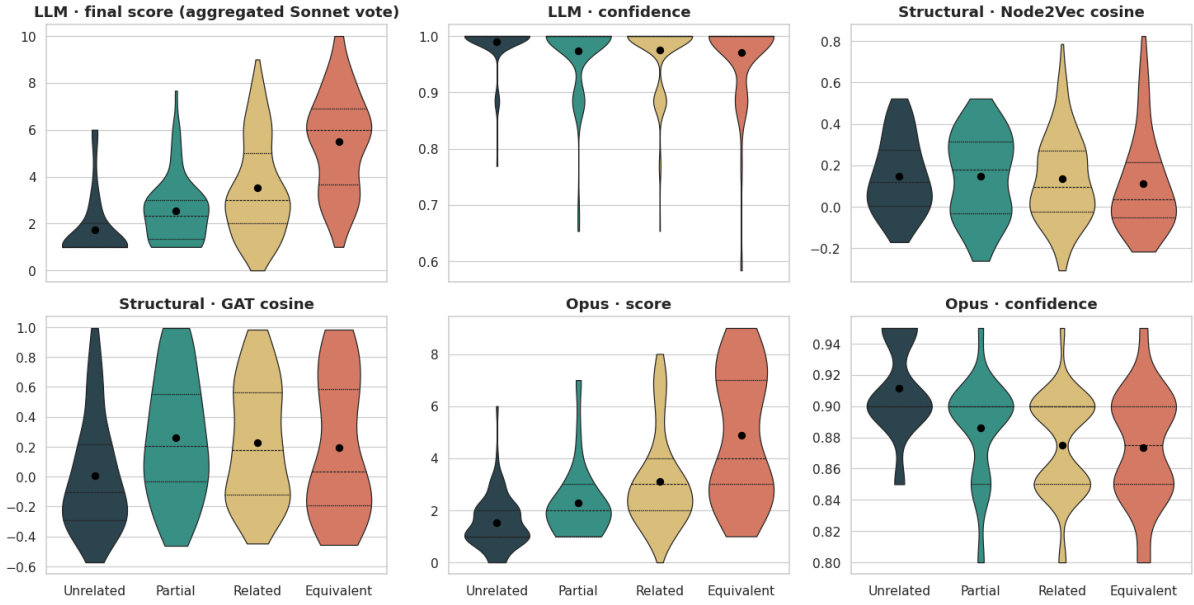


Figure 5: Distribution of six representative features stratified by expert tier label. Each panel shows violin and strip plots for one feature across the four tiers, illustrating the per-family discriminative signal.

- **Hyperparameters:** `n_estimators` = 500, learning rate = 0.05, `min_samples_leaf` = 5.
- **Class weights:** Inverse-frequency weighting to compensate for class imbalance.
- **Training data:** 1,515 LLM-SME labeled pairs.
- **Calibration data:** 150 held-out pairs for Mondrian conformal calibration.
- **Test data:** 400 expert-labeled frozen pairs (`v1_frozen`), never seen during training or tuning. SHA-256 hash verification ensures immutability.

5.3 Evaluation Metrics

We report four accuracy metrics at increasing granularity:

- **Tier accuracy:** Exact-match accuracy across the four tiers.
- **Adjacent accuracy:** Fraction of predictions within ± 1 tier of the ground-truth label, capturing near-miss performance on an ordinal scale.
- **Binary accuracy:** Accuracy after collapsing tiers into a binary “related or stronger” vs. “partial or weaker” distinction.
- **Macro F1:** Unweighted average of per-class F1 scores, treating all four tiers equally regardless of prevalence.

Additionally, we report per-class precision, recall, and F1, as well as Mondrian conformal coverage and mean prediction set size at $\alpha = 0.10$. All confidence intervals are computed via 10,000-iteration bootstrap resampling.

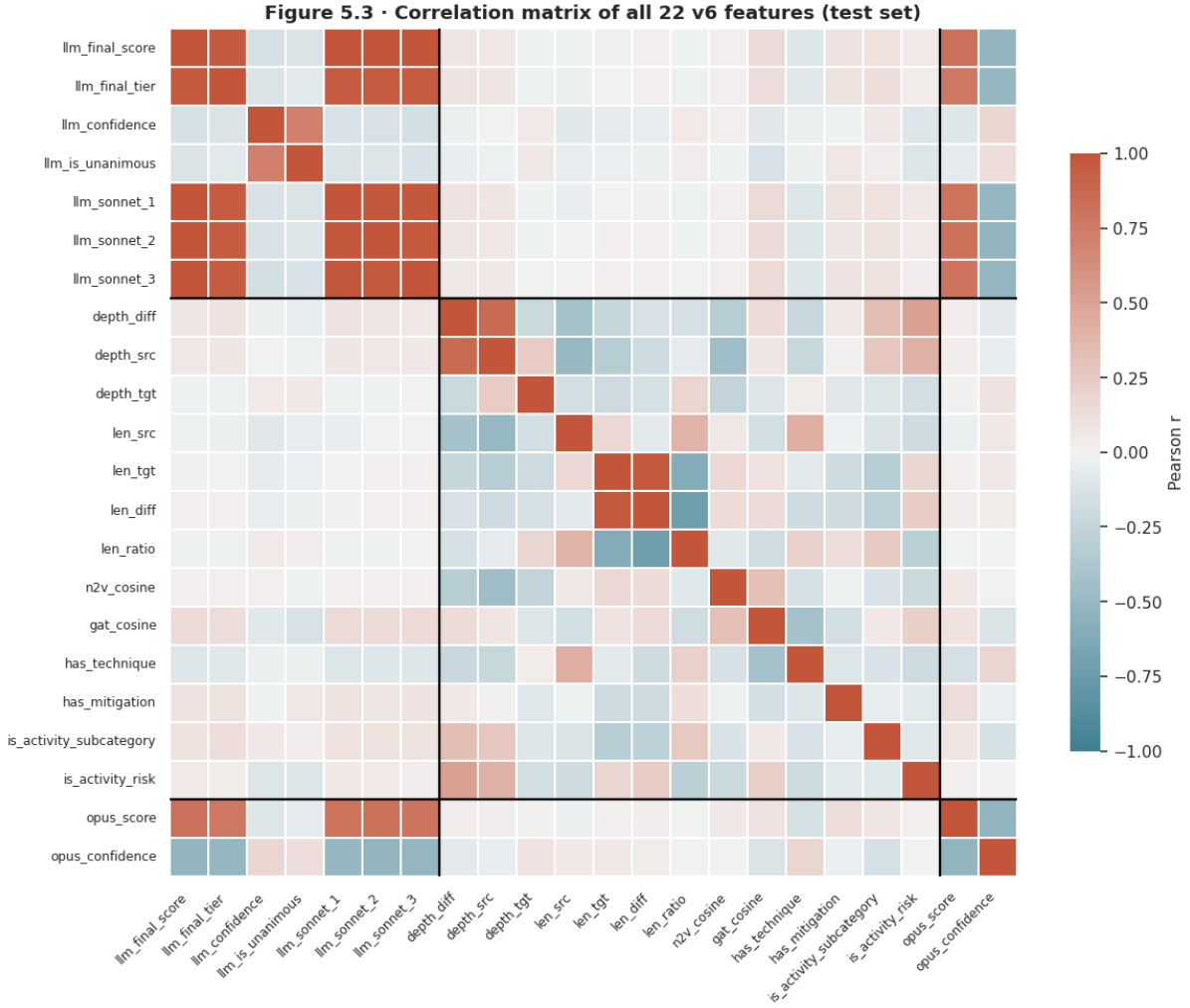


Figure 6: Pearson correlation matrix of all 22 v6 features on the test set ($n = 400$). Black lines delineate the three feature families (LLM, Structural, Opus). Cross-family correlations are generally low, confirming that the three signal families capture complementary information.

6 Results

6.1 Main Results

Table 1 summarizes performance on the 400 expert-labeled frozen test set. The full 22-feature model achieves:

- **Tier accuracy:** 0.5325 (95% CI [0.485, 0.580])
- **Macro F1:** 0.4888 (95% CI [0.433, 0.538])
- **Adjacent accuracy:** 0.8425 — 84% of predictions fall within one tier of the ground-truth label
- **Binary accuracy:** 0.7125

6.2 Per-Class Analysis

Performance varies substantially across tiers. The Related class, which dominates the test distribution (186/400), achieves the highest F1 (0.613) and accuracy (0.640). The Unrelated

Table 1: Results on `human_test_frozen` ($n = 400$). Per-class rows show F1 / accuracy with support counts in parentheses.

Metric	Value
Tier accuracy	0.5325
Macro F1	0.4888
Adjacent accuracy	0.8425
Binary accuracy	0.7125
95% CI (accuracy)	[0.485, 0.580]
95% CI (F1)	[0.433, 0.538]
Equivalent (58)	0.454 / 0.379
Related (186)	0.613 / 0.640
Partial (78)	0.364 / 0.308
Unrelated (78)	0.525 / 0.615
Conformal coverage ($\alpha=0.10$)	0.9375
Mean prediction set size	3.20
Calibration set size	150

class (78/400) benefits from clear semantic separation, reaching F1 of 0.525 and accuracy of 0.615.

The Equivalent class (58/400) achieves F1 of 0.454 and accuracy of 0.379. While below the overall average, this represents meaningful discrimination for the most demanding tier, where the model must distinguish full semantic equivalence from strong relatedness. The Partial class (78/400) remains the most challenging at F1 of 0.364 and accuracy of 0.308, consistent with the inherent subjectivity of partial-overlap judgments noted in prior crosswalk studies.

The confusion matrix reveals that the primary error mode is over-prediction of the Related tier: 28/58 Equivalent pairs are predicted as Related, and 35/78 Partial pairs are predicted as Related. This “gravitational pull” toward the majority class persists despite inverse-frequency weighting, suggesting that the boundary between Related and its neighboring tiers is genuinely ambiguous in the feature space.

6.3 Conformal Coverage

The Mondrian conformal predictor achieves empirical coverage of 93.8% at $\alpha = 0.10$, closely meeting the nominal 90% target. The mean prediction set size is 3.20 out of four possible classes, indicating that the conformal wrapper is conservative: for most instances, it retains three of the four tiers in the prediction set to maintain coverage. This conservatism is expected given the ordinal structure of the tier scheme and the moderate discriminative power of the underlying classifier. Figure 10 shows the distribution of prediction set sizes stratified by true tier.

6.4 Expert–LLM Label Gap

On the 379 LLM-labeled validation set, accuracy rises to approximately 0.65, reflecting a distribution gap between expert and LLM labeling. This gap is most pronounced for the Partial and Equivalent tiers, where expert annotators apply stricter criteria for semantic overlap than the LLM-SME labeling protocol. The gap motivates our emphasis on expert-labeled evaluation and highlights the importance of the frozen test set for honest benchmarking.

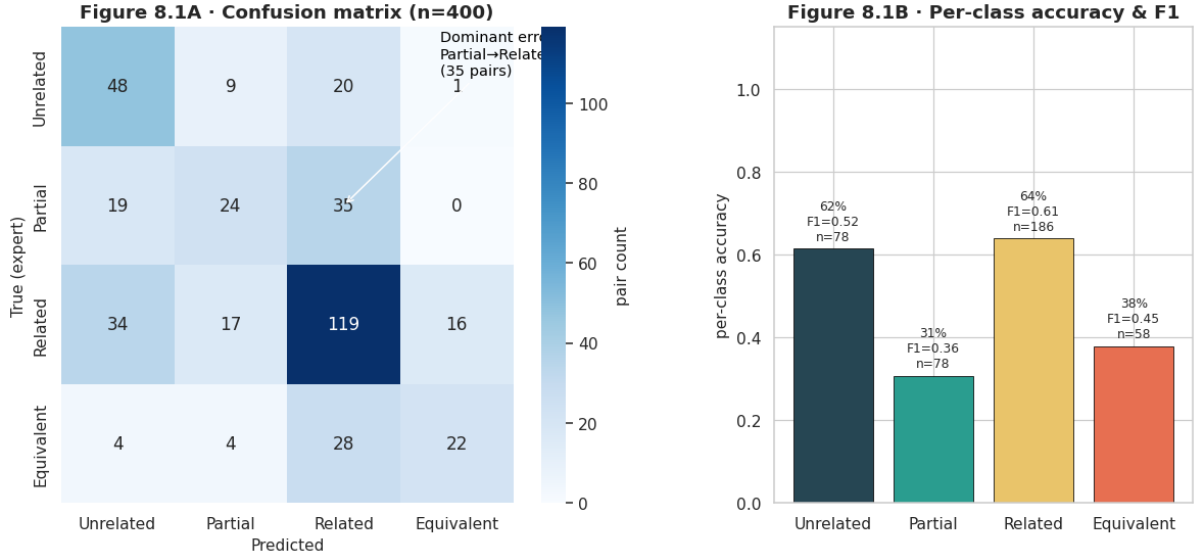


Figure 7: GBM model performance on the frozen test set ($n = 400$). (A) Confusion matrix showing predicted vs. true tier labels. (B) Per-class accuracy and F1 scores with support counts.

Table 2: Feature-family ablation on `human_test_frozen` ($n = 400$). All variants use the same LightGBM hyperparameters.

Feature set	Dims	Tier Acc	Macro F1	Adj Acc
LLM only	7	0.468	0.418	0.858
Structural only	13	0.393	0.317	0.750
Opus only	2	0.523	0.382	0.843
LLM + Struct	20	0.495	0.444	0.855
LLM + Opus	9	0.463	0.416	0.818
Struct + Opus	15	0.495	0.432	0.835
All (LLM+Struct+Opus)	22	0.533	0.489	0.843

7 Ablation Study

We conduct ablation experiments to quantify the contribution of each feature family. All ablations use the same LightGBM hyperparameters (`n_estimators` = 500, `lr` = 0.05, `min_samples_leaf` = 5) and are evaluated on the frozen expert test set ($n = 400$).

7.1 Key Findings

- **All three families contribute.** The full 22-feature model (0.533 accuracy, 0.489 macro F1) outperforms every subset, confirming that the three signal families capture complementary information.
- **Opus scores are the strongest single channel.** The two-dimensional Opus-only model achieves 0.523 accuracy, nearly matching the full model. This demonstrates that a well-calibrated LLM-as-judge provides a strong prior that the stacker refines rather than replaces.
- **LLM features outperform structural features in isolation.** LLM-only (7d) reaches 0.468 accuracy versus 0.393 for Structural-only (13d), a 7.5 percentage-point gap. However, Structural features provide the largest marginal gain when combined: LLM+Struct

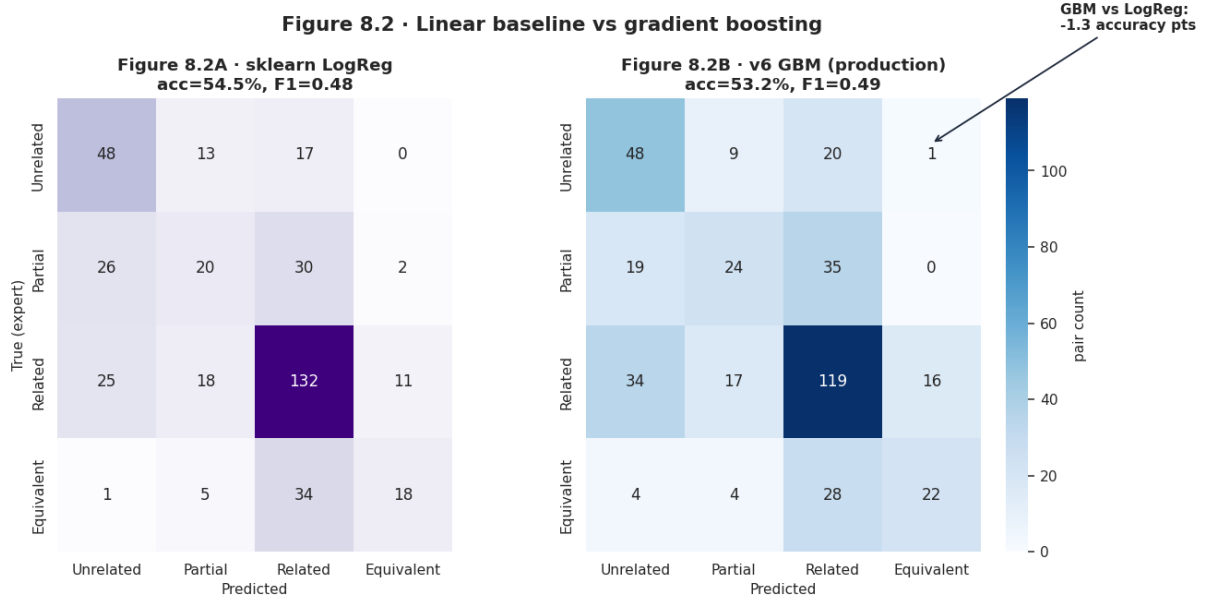


Figure 8: Comparison of linear baseline vs. gradient boosting. (A) Logistic regression confusion matrix. (B) v6 GBM (production) confusion matrix. The GBM substantially improves discrimination for the Unrelated and Equivalent tiers.

(0.495) exceeds LLM-only by 2.7 pp, while LLM+Opus (0.463) is slightly below LLM-only, suggesting the Opus signal partially overlaps with the LLM embedding signal.

- **Structural features reduce adjacent-accuracy degradation.** Structural-only has the lowest adjacent accuracy (0.750), but adding structural features to Opus (Struct+Opus: 0.835) provides better ordinal calibration than LLM+Opus (0.818), indicating that graph topology helps the model respect the ordinal tier structure.
- **The full model is Pareto-optimal.** No subset achieves higher accuracy, F1, or adjacent accuracy than the full model, justifying the inclusion of all three feature families despite the modest dimensionality overhead.

These results confirm that the stacking approach, combining text similarity, graph structure, and LLM judgment in a single gradient boosting model, captures relational structure that no single signal family provides alone.

8 Limitations

Moderate tier accuracy on expert labels. The system achieves 0.53 tier accuracy on expert-labeled data, meaning roughly half of all predictions match the exact tier assigned by a human expert. While adjacent accuracy (0.84) demonstrates that most errors are near-misses on an ordinal scale, exact-match performance remains a barrier to fully unsupervised deployment. The primary error mode is over-prediction of the Related tier, which acts as an attractor for both Equivalent and Partial pairs.

Partial-tier confusion. The Partial class achieves the lowest per-class F1 (0.364) and accuracy (0.308). The boundary between Partial and its neighbors (Unrelated and Related) is inherently subjective: reasonable experts disagree on whether a control “partially addresses” another versus being merely “related to” it. This ambiguity is reflected in the confusion matrix,

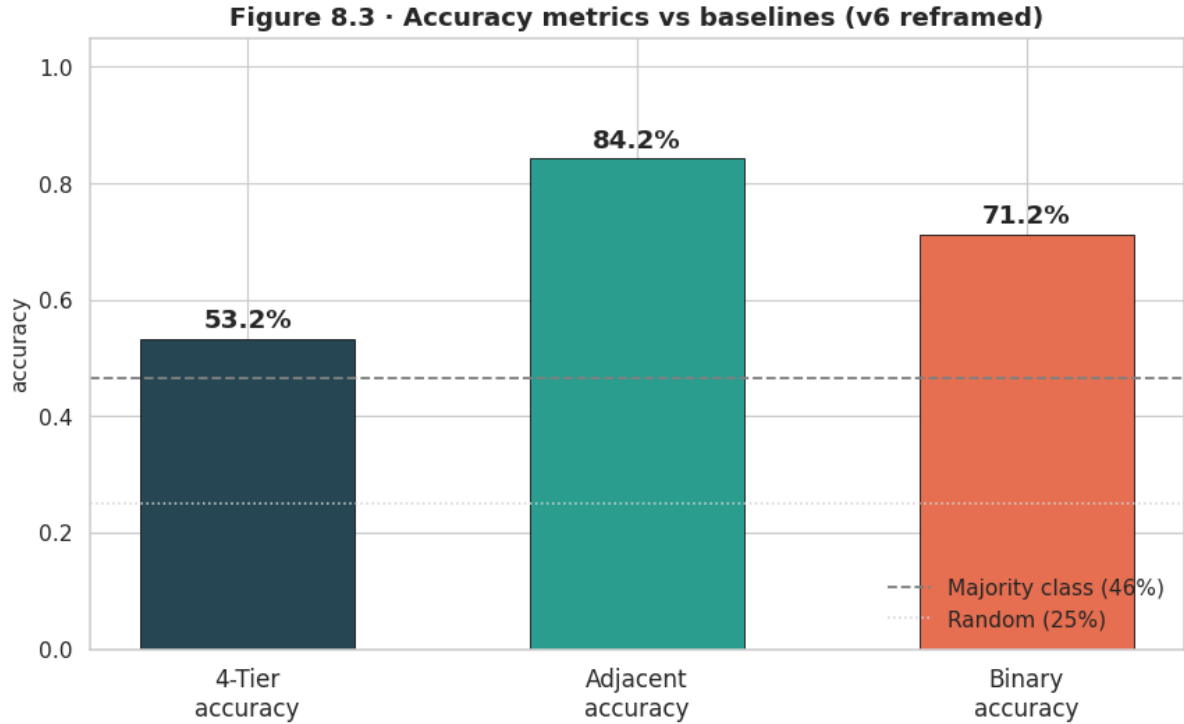


Figure 9: Tier accuracy, adjacent accuracy, and binary accuracy for the v6 GBM compared against random and majority-class baselines. The GBM exceeds all baselines across every metric.

where 35/78 Partial pairs are predicted as Related and 19/78 as Unrelated. Improving Partial discrimination likely requires richer annotation guidelines or multi-annotator consensus labels.

Expert-LLM label distribution gap. The 12-point accuracy gap between LLM-labeled validation (~ 0.65) and expert-labeled test (0.53) indicates that the LLM-SME labeling protocol produces systematically different tier distributions from human experts, particularly for the Partial and Equivalent tiers. Training on LLM labels while evaluating on expert labels introduces a distribution shift that limits classifier performance.

Conservative conformal sets. Mondrian conformal prediction achieves 93.8% coverage, exceeding the nominal 90% target, but at the cost of large prediction sets (mean size 3.20 out of 4 classes). This conservatism limits the practical utility of conformal prediction for downstream decision-making: in most cases, the prediction set does not meaningfully narrow the tier possibilities. Tighter sets would require either a more discriminative base classifier or a larger calibration set.

Sparse framework connectivity. Only 15 of the 36 possible framework pairs (41.7%) have cross-framework edges in the current graph. The remaining 21 pairs have no direct mapping evidence, meaning the classifier must rely entirely on text similarity and Opus judgment for those pairs. Expanding upstream data sources or applying zero-shot graph construction methods would improve coverage.

Framework coverage and generalization. The current system covers nine AI security frameworks. Generalization to new frameworks requires ingestion of control texts and ideally some anchor edges, though the Opus tier-score features provide a framework-agnostic baseline signal. Evaluation on out-of-distribution frameworks has not been conducted.

Figure 9.1 · Conformal prediction set sizes by tier

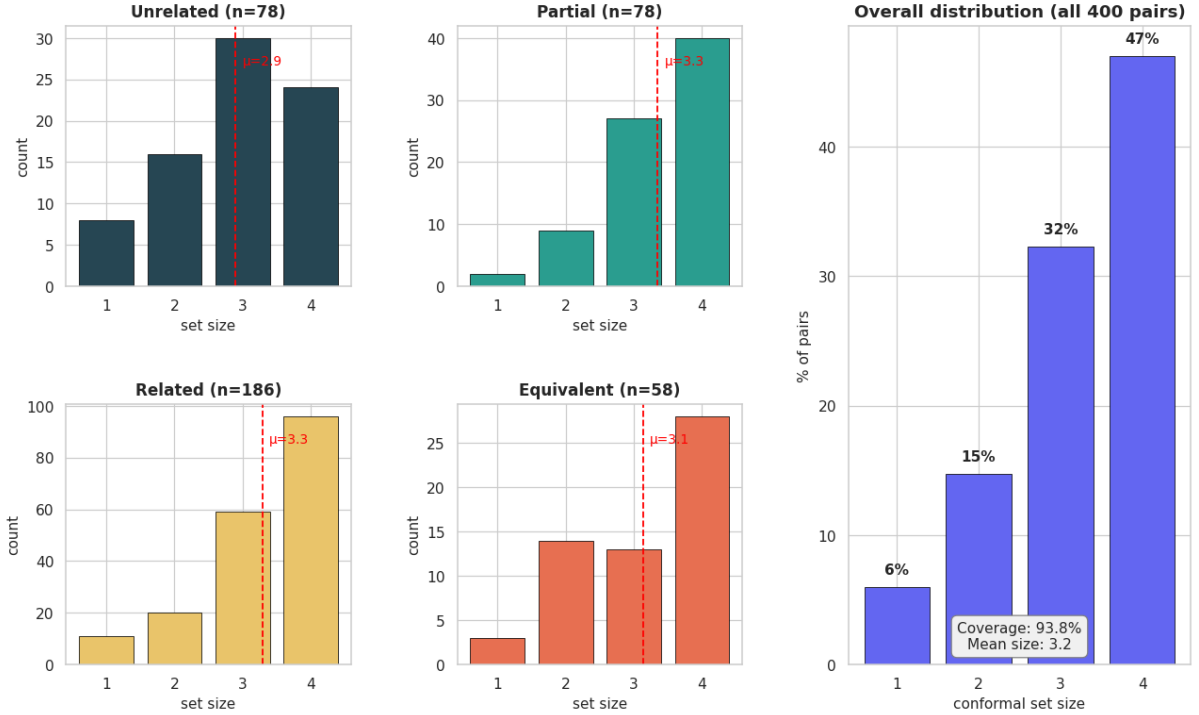


Figure 10: Conformal prediction set size distributions by true tier. Most instances receive prediction sets of size 3–4, reflecting the conservative calibration needed to achieve 93.8% coverage.

Temporal validity. Framework versions are pinned at ingestion time. As frameworks evolve, the crosswalk will require periodic re-ingestion, re-featurization, and re-evaluation. The modular pipeline design facilitates this, but the cost of re-labeling expert test sets for updated frameworks is non-trivial.

9 Ethics Statement

This work aims to assist security practitioners in navigating the complex landscape of AI security frameworks. The crosswalk system is intended as a decision-support tool and should not replace expert judgment. Predicted mappings, especially those not confirmed by the conformal predictor with small prediction sets, should be reviewed by qualified subject matter experts before being used in compliance decisions.

The training data includes publicly available framework texts and community-contributed crosswalk data released under permissive licenses (CC BY-SA 4.0 for upstream GenAI Security Project data [GenAI Security Project Contributors, 2024]; Apache-2.0 for our code and model weights). No personally identifiable information is used in any stage of the pipeline.

The LLM-as-judge component uses a commercial language model for feature extraction during training. We report this dependency transparently and note that the resulting features are deterministic given the same model version and prompts. The expert-labeled test set was produced by a single annotator; future work should expand to multiple independent annotators to assess inter-rater reliability and reduce potential bias in the gold standard.

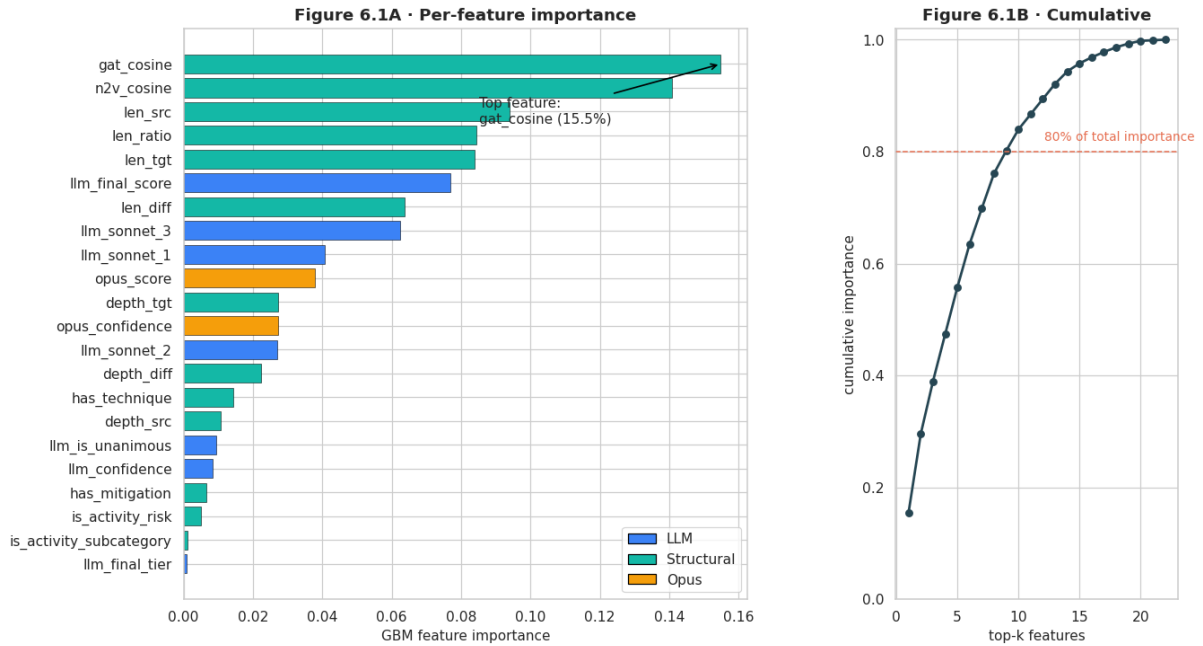


Figure 11: LightGBM feature importance. (A) Per-feature importance for all 22 features, colored by family. (B) Cumulative importance curve. The top five features capture over 60% of the total importance budget.

10 Reproducibility

We prioritize full reproducibility of all reported results:

- **One-command reproduction.** Running `make reproduce` verifies frozen-split integrity via SHA-256 hashes, re-evaluates the trained model on the frozen test set, and reports all metrics from Section 6.
- **Pinned dependencies.** All Python dependencies are pinned in `requirements.txt` with exact versions.
- **Frozen test splits.** The 400 expert-labeled test pairs are stored in `data/splits/human_test_frozen.json` with a derived `frozen_tuples.json` file. A SHA-256 hash verification contract test ensures these files are never inadvertently modified.
- **Sacred experiment tracking.** The canonical run (v6-reframed, SHA 3c2e531) is logged with all hyperparameters, random seeds, feature definitions, and metric values recorded in `results/sacred/sacred_3c2e531.json`.
- **Four-source data provenance.** All upstream data sources (community mappings, cross-references, and bootstrap-pruned anchor pairs) are versioned in the repository with their generation scripts.
- **Source code.** The complete codebase is released under the Apache-2.0 license.

Acknowledgements

We thank the contributors to the GenAI Security Project for producing the community-driven crosswalk data that serves as an upstream data source for this work (used under CC BY-SA 4.0). We also thank the OWASP community for their ongoing work on AI security framework

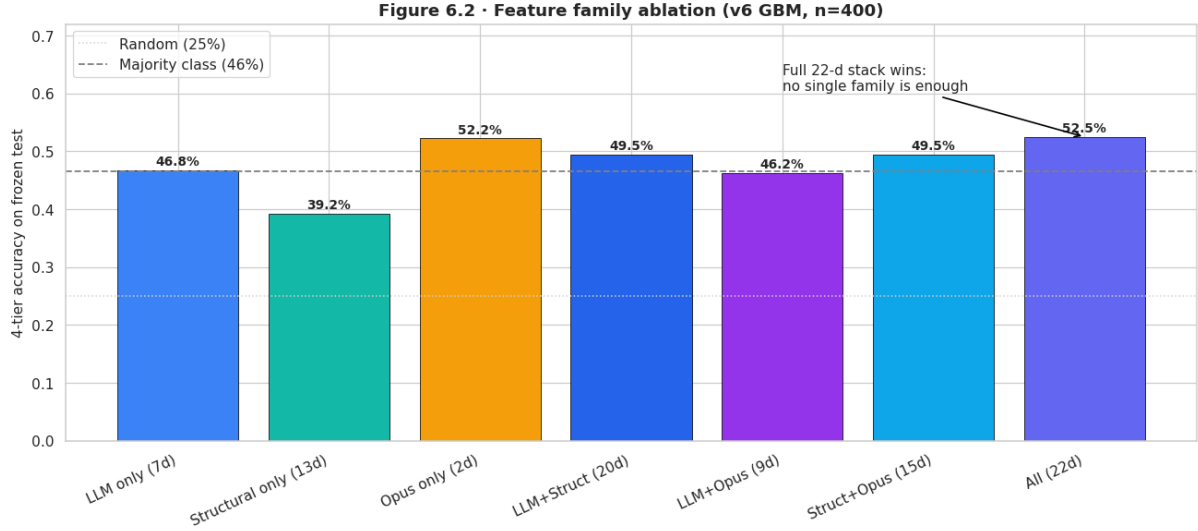


Figure 12: Feature family ablation results on the frozen test set ($n = 400$). Tier accuracy for GBM models trained with different feature-family subsets. The full model (All) achieves the highest accuracy.

taxonomies that inform our graph construction, and the Cloud Security Alliance for publishing the AI Controls Matrix.

References

- Shaked Brody, Uri Alon, and Eran Yahav. How attentive are graph attention networks? In *International Conference on Learning Representations (ICLR)*, 2022.
- Cloud Security Alliance. CSA AI controls matrix. <https://cloudsecurityalliance.org/research/topics/ai-controls-matrix>, 2024.
- GenAI Security Project Contributors. GenAI security project: Cross-framework mapping. <https://genaisecurityproject.com/>, 2024. Licensed under CC BY-SA 4.0.
- Guolin Ke, Qi Meng, Thomas Finley, Taifeng Wang, Wei Chen, Weidong Ma, Qiwei Ye, and Tie-Yan Liu. LightGBM: A highly efficient gradient boosting decision tree. In *Advances in Neural Information Processing Systems (NeurIPS)*, 2017.
- MITRE Corporation. MITRE ATLAS: Adversarial threat landscape for AI systems. <https://atlas.mitre.org/>, 2024.
- National Institute of Standards and Technology. Artificial intelligence risk management framework (AI RMF 1.0). Technical Report NIST AI 100-1, NIST, 2023.
- OWASP Foundation. OWASP top 10 for large language model applications. <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, 2025.
- Yaniv Romano, Matteo Sesia, and Emmanuel J. Candès. Classification with valid and adaptive coverage. In *Advances in Neural Information Processing Systems (NeurIPS)*, 2020.
- Petar Veličković, Guillem Cucurull, Arantxa Casanova, Adriana Romero, Pietro Liò, and Yoshua Bengio. Graph attention networks. In *International Conference on Learning Representations (ICLR)*, 2018.

Vladimir Vovk, Alex Gammernan, and Glenn Shafer. *Algorithmic Learning in a Random World*. Springer, 2005.